

Introducción al análisis forense en dispositivos móviles

Mariano Sánchez Martín (a partir de
un original de Rafael López García)



GOBIERNO
DE ESPAÑA

MINISTERIO
DE EDUCACIÓN
Y FORMACIÓN PROFESIONAL



Unión Europea-
NextGenerationEU



XUNTA
DE GALICIA

INSTITUTO EDUCACIÓN
SECUNDARIA
SAN CLEMENTE

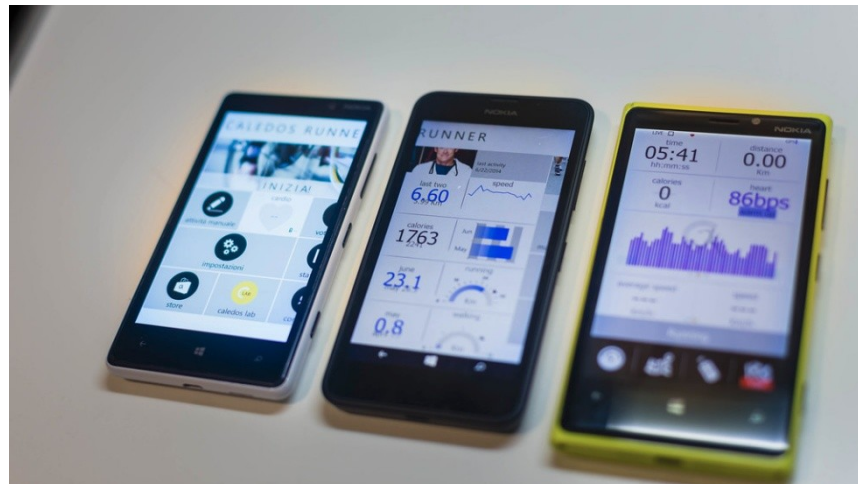
Parte I: Contexto

Motivación (I)

- Los dispositivos móviles cada vez **predominan más** con respecto a los de sobremesa
 - Más datos a obtener
 - Más peligros ahí fuera
- Sobre el 85% del malware se hace para móviles
- Nuevas formas de ataque como el [juice jacking](#)

Motivación (II)

- Más datos a obtener
 - Los dispositivos móviles nos **proporcionan hábitos de vida** de su dueño
 - Gran cantidad de apps que hacen “telemetría” de nuestra vida
 - Los asistentes de voz nos escuchan constantemente



Situaciones de forense en móviles

- Tras un delito o incidente de seguridad
- Auditoría de seguridad
 - Mantenimiento de la privacidad, transmisiones de datos seguras, etc.
 - Revisar el cumplimiento de regulaciones y estándares de seguridad
 - Verificar que los usuarios destruyen datos sensibles debidamente

Peculiaridades de forense en móviles (I)

- Antes todo era en un entorno cerrado
 - PC, servidores, red.
- Con la aparición del teléfono móvil
 - **Fuera del entorno de la empresa**
 - **Nuevos tipos de datos:** llamadas, SMS
- Con la aparición del Smartphone
 - Nuevos datos: localizaciones, mensajes, emails
- La situación se agrava con *wearables*, vehículos inteligentes, IoT, etc.

Peculiaridades de forense en móviles (II)

- **Sistemas operativos distintos**
 - Mayoritariamente Android e iOS
 - Millones de aplicaciones para muchos dispositivos (incluso aplicaciones efímeras)
- **Más técnicas antiforense**
 - Nuevas formas de destrucción, ocultación y falsificación de evidencias
 - P.ej.: según metas un código u otro arranca una ROM u otra (con un bootloader), y una de ellas es falsa

Peculiaridades de forense en móviles (III)

- **Más consideraciones legales**
 - Más difícil respetar las regulaciones para mantener la legalidad de las evidencias
 - P. ej.: la autorización judicial puede no incluir la nube
 - P. ej.: puede haber la posibilidad de enviar una petición especial para obtener todos los datos de un usuario en alguna red social

Peculiaridades de forense en móviles (IV)

- **Mayor protección y cifrado por defecto**
 - Desbloqueo del dispositivo
 - A veces no deja ni acceder por cable
 - Cifrado del almacenamiento
 - No se puede leer ni accediendo físicamente al chip
 - Remote wipe
 - Borrado de evidencias sin tener acceso físico al dispositivo

Metodología

- Metodología heredada de la de PC
 1. Identificación y adquisición de evidencias
 2. Preservación de las evidencias
 3. Análisis de las evidencias
 4. Documentación y presentación de los resultados

Guías

- Aplican la mayoría de las que hemos visto
 - RFC 3227, etc.
- Guías específicas:
 - [Guidelines on Mobile Device Forensics](#) de NIST
 - [Developing Process for Mobile Device Forensics](#) de SANS
 - [Best Practices for Mobile Phone Forensics](#) de SWGDE

Parte II: Adquisición

Preparación (I)

- A diferencia del forense de PC, puede requerir una **actuación más rápida**
 - Evitar la modificación o el borrado remoto de evidencias
 - Meterlo en una jaula (bolsa) de Faraday para aislarlo de señales externas
 - <https://paraben.com/wireless-device-protection/>
 - Evitar que se quede sin alimentación eléctrica
 - Es más probable encontrar un móvil sumergido en agua que un PC

Preparación (II)

- Si el móvil está sumergido...
 1. Apagar y quitar la batería si es posible
 2. Sumergirlo en alcohol isopropílico (isopropanol) o n-propanol durante varios minutos para quitar el agua
 3. Aplicar papel secante (y si no avena, arroz, etc.)*
- Y además tener en cuenta...
 - No usar secadores ni otras fuentes de calor
 - El agua salada es mucho más corrosiva que la dulce, más probable que no podamos hacer nada

Preparación (III)

CREADORES

Apple advierte de que no es recomendable poner un iPhone mojado en arroz para secarlo

Según la compañía estadounidense, "hacerlo podría permitir que pequeñas partículas de arroz dañen tu iPhone"



2 comentarios



Varios modelos de iPhone en una tienda de Apple de Nueva York. RICHARD DREW AP

Adquisición

- Depende mucho de:
 - Tipo de dispositivo
 - Android, iPhone, Windows Phone, BlackBerry...
 - Versión específica de hardware y software
 - Configuración del dispositivo
 - Nivel de desbloqueo: apagado/encendido, bloqueado/desbloqueado, rooteado, etc.
 - Tipos de datos a adquirir y su volatilidad
 - Memoria, almacenamiento persistente

Tipos de adquisición: manual

- Interactuamos con el dispositivo, tomamos capturas de pantalla, fotos de la pantalla, etc.
- Ventajas
 - No requiere herramientas
 - Información fácil de entender para no expertos
- Desventajas
 - Sólo es posible si el dispositivo está desbloqueado
 - Sólo se puede acceder a datos en pantalla
 - Posible modificación de la información
 - Lleva más procesar las evidencias

Tipos de adquisición: lógica

- Copiar archivos y directorios del sistema
- Ventajas
 - Fácil de obtener, no requiere hardware específico
 - A veces se puede hacer desde otro dispositivo sin emplear las API del móvil
- Desventajas
 - Si usa las API del móvil, pasa por el SO comprometido
 - No copia archivos borrados o información oculta en el sistema de archivos
 - Depende de los permisos del sistema de ficheros

Tipos de adquisición: física

- Copia bit a bit
- Ventajas
 - Se puede acceder a archivos borrados, zonas de almacenamiento no usadas, etc.
- Desventajas
 - Muy complejo y no siempre factible
 - Requiere acceso completo al almacenamiento, el cual no está siempre accesible físicamente
 - En muchas ocasiones necesitamos emplear exploits para saltarnos la seguridad y poder acceder

Tipos de almacenamiento

- Memorias flash NAND
 - La más típica para almacenamiento.
 - De lectura y escritura
- Memorias flash NOR
 - Optimiza la ejecución de código
 - Similar al anterior, pero su uso ha decrecido
- Las tarjetas de memoria suelen usar memorias NAND y estar formateadas en FAT32
 - iPhone/iOS no permite su uso
 - Los otros fabricantes, depende del dispositivo

Acceso según el estado del dispositivo (I)

- Dispositivo desbloqueado (Before First Unlock)
 1. Garantizar alimentación eléctrica y aislarlo de la red
 - Ponerlo en modo avión,
 - Extraer la tarjeta SIM
 2. Tratar de garantizar el acceso físico
 - Desactivar el código de bloqueo si es posible
 - Activar el debugging USB
 - Desactivar o retrasar el bloqueo por inactividad
 3. Meterlo en una bolsa de Faraday que lo aíse de radiación electromagnética
 4. Obtener tarjetas SD, backups en PC asociados, etc.

Acceso según el estado del dispositivo (II)

- Dispositivo bloqueado (After First Unlock)
 1. Aislarlo de la red
 - Modo avión + extraer SIM
 2. Comprobar si el debugging USB está activado
 1. Si lo está, tratar de cargar un bootloader para cambiar el inicio y activar el acceso físico al terminal
 2. Si no lo está, tratar de extraer el código de bloqueo ([smudge attack](#), fuerza bruta, vulnerabilidades, etc.)
 3. Meterlo en una bolsa de Faraday
 4. Obtener tarjetas SD, backups en PC asociados...

Acceso según el estado del dispositivo (III)

- Dispositivo apagado
 1. Quitar los dispositivos extraíbles
 2. Encender el teléfono
 3. Actuar como en el caso de dispositivo bloqueado
- Alternativa si el dispositivo está bloqueado:
usar una herramienta de pago que nos
permita obtener el código de entrada

Herramientas de adquisición (I)

- Cellebrite UFED
 - <https://cellebrite.com/es/cellebrite-ufed-es/>
- Oxygen Forensics Detective
 - <https://www.oxygen-forensic.com/es/>

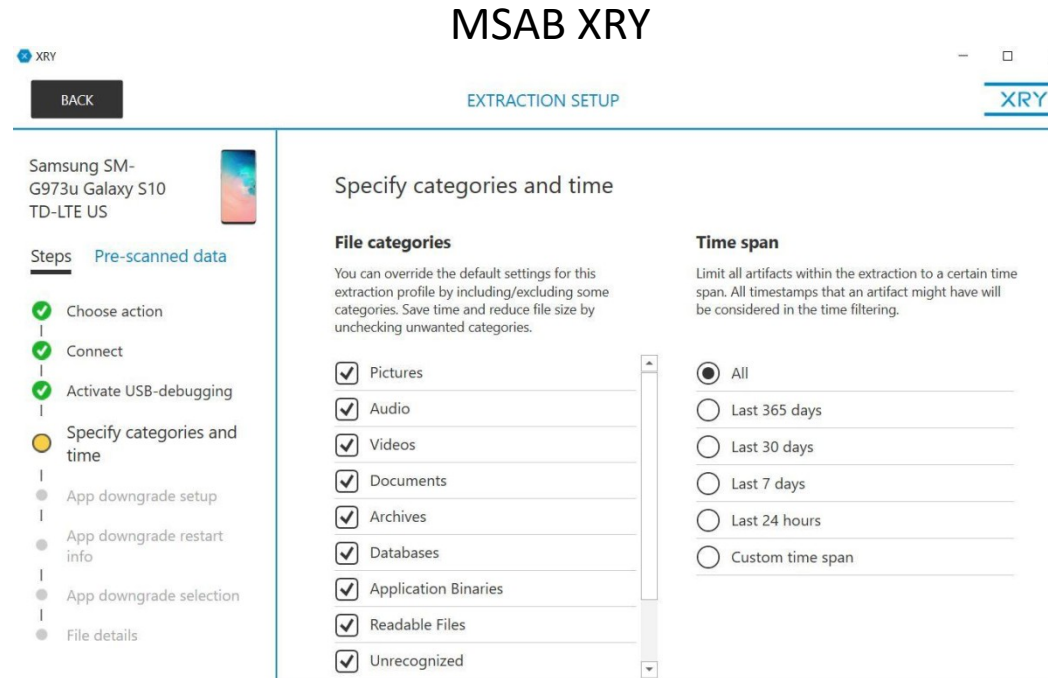
Cellebrite UFED Touch 2



Fuente de la imagen: <https://onretrieval.com/cellebrite-ufed-touch-2-review/>

Herramientas de adquisición (II)

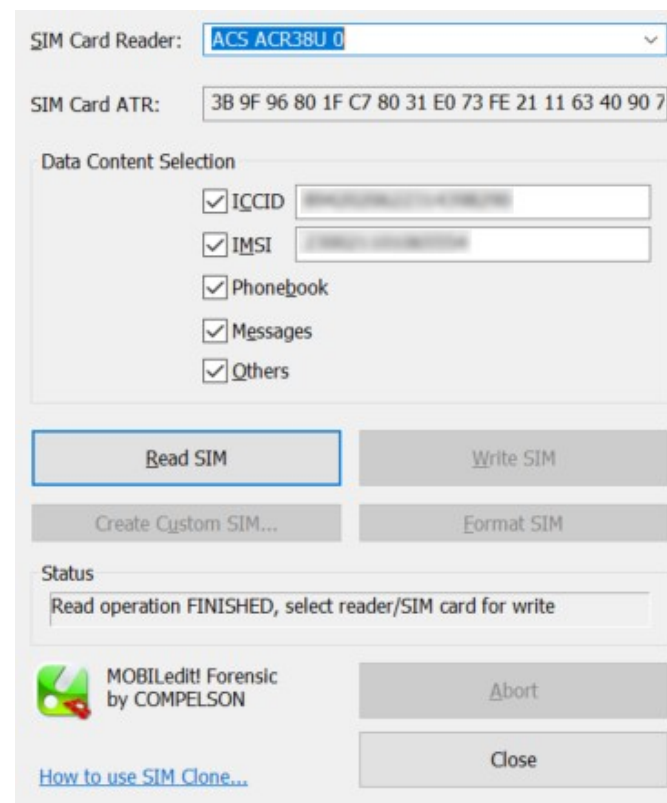
- MSAB
 - XRY Physical
 - XRY Logical
 - XRY Cloud
 - Nubes del móvil
 - XRY Pinpoint
 - Móviles asiáticos
 - XRY Camera



Fuente de la imagen: <https://www.forensicfocus.com/reviews/xry-v9-3-from-msab/>

Herramientas de adquisición (III)

- MOBILedit Forensic, SIM Cloning Tool, etc.
 - <https://www.mobiledit.com/downloads>

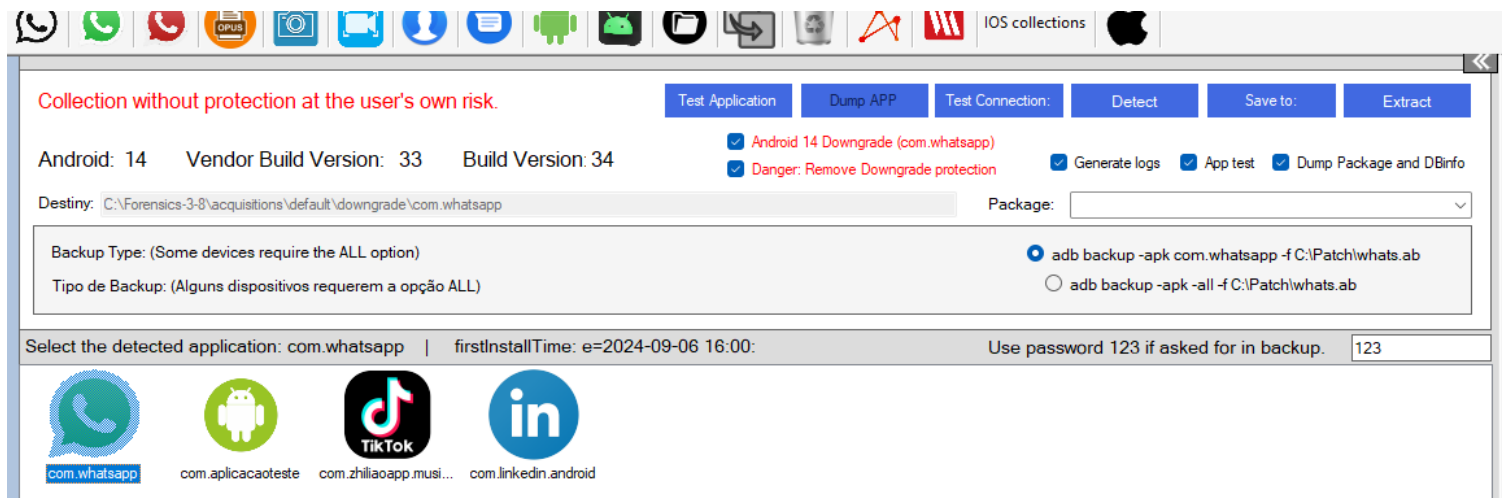


Herramientas de adquisición (IV)

- Belkasoft Remote Acquisition
 - <https://belkasoft.com/r>
- ForensicToolKit – FTK (AccessData - Exterro)
 - <https://www.exterro.com/forensic-toolkit>
- Axion Cyber (Magnet)
 - <https://www.magnetforensics.com/products/magnet-axion-cyber>

Herramientas de adquisición (V)

- En software libre para examinar Android, tenemos Avilla Forensics
 - Permite técnicas de downgrade de diversas apps para extraer datos de las zonas privadas
 - <https://github.com/AvillaDaniel/AvillaForensics>



Herramientas de adquisición (VI)

- Por último, tenemos la alternativa de operar a bajo nivel
 - P. ej.: ADB backup + dd
 - P. ej.: Pequeñas herramientas de downgrade para acceder a datos privados de ciertas apps
- **Si no somos root, muchos menos datos extraídos**

Parte III: Análisis

El IMEI (I)

- El IMEI (*International Mobile Equipment Identity*) es un código de 15 dígitos que identifica al teléfono
 - País de fabricación del teléfono
 - Fabricante
 - Número de serie del teléfono
 - Dígito de control
- Se puede obtener marcando *#06#

El IMEI (II)

- Se puede obtener información de los dispositivos en <https://www.imei.info>
 - <https://www.imei.info/?imei=010928003890233>



BASIC INFO

[Full device specification >](#)

Device type	Smartphone	LTE / 5G	✓ / ✓
Released	09 2021	Battery	Li-Ion, 3227.0 mah
Operating System	iOS 17	Built-in NFC	✓
Chipset	Apple A15 Bionic	Display	RETINA 71.5 x 146.7px (6.1)
SIM card size	Nano Sim, eSIM	Built-in GPS	✓
GPU Type	Apple GPU	Dimensions (H/L/W)	146.7 x x 71.5 mm
Available colors	Starlight, Midnight, Blue, Pink, Red	Main Camera	12.19MPx / px
Available memory x	128GB / 256GB / 512GB	Selfie Camera	12.19MPx / px

Artefactos en dispositivos móviles

- Contactos
- Cuentas de usuario
- Historial de llamadas
- SMS, MMS
- Conversaciones de aplicaciones de mensajería
- Correos electrónicos
- Publicaciones en RRSS
- Aplicaciones instaladas
- Historial de localizaciones
- Historial de búsquedas
- Historial de navegación
- Caché del teclado
- Datos de los sensores del dispositivo
- Calendario
- Documentos
- Fotos, vídeos, audios
- Credenciales de redes WiFi
- Datos eliminados

Otras herramientas

- Lectura y escritura a bajo nivel: dd y similares
- Visores hexadecimales
 - [HxD](#) (Windows), gHex, Bless (Linux), iHex (MacOS)
- Visor y editor SQLite
 - Es la base de datos más popular para que las aplicaciones persistan sus datos
 - [SQLiteBrowser](#), [SQLiteman](#)
- Editor de textos, grep, strings, exiftool...

MobSF (I)

- Framework automático y todo en uno para pentesting de aplicaciones, análisis de malware y evaluación de seguridad
 - <https://github.com/MobSF/Mobile-Security-Framework-MobSF>



MobSF (II)

MobSF

Static Analysis

Information

Code Nature

Signer Certificate

Permissions

Android API

Security Analysis

Reconnaissance

Components

Download Report

Recent Scans

About

Search MD5

File Information

Name

diva-beta.apk

Size

1.43MB

MD5

82ab8b2193b3cfb1c737e3a786be363a

SHA1

27e849d9d7b86a3a3357fb3e980433a91d416801

SHA256

5cfc51fce9bd760b92ab2340477f4dda84b4ae0c5d04a8c9493e4fe34fab7c5

App Information

Package Name

jakhar.aseem.diva

Main Activity

jakhar.aseem.diva.MainActivity

Target SDK

23

Min SDK

15

Max SDK

Android Version Name

1.0

Android Version Code

1

17

ACTIVITIES

View

0

SERVICES

View

0

RECEIVERS

View

1

PROVIDERS

View

EXPORTED ACTIVITIES

2

EXPORTED SERVICES

0

EXPORTED RECEIVERS

0

EXPORTED PROVIDERS

1

Code Nature

Native

True

Dynamic

False

Reflection

True

Crypto

True

Obfuscation

False

Options

</> View Java

Download Java Code

</> View Smali

Download Smali Code

Rescan

View AndroidManifest.xml

Start Dynamic Analysis

Bibliografía y webgrafía

Bibliografía y webgrafía (I)

- César Cabanas Burkhalter y Alberto Castro Ortiz en CCN - Amenazas y Tendencias (APT) *“Preparación de dispositivos móviles para su análisis”*
 - [https://
www.youtube.com/watch?v=xQrpDrYMQ74](https://www.youtube.com/watch?v=xQrpDrYMQ74)